

An official website of the United States government [Here's how you know](#)**CYBERSECURITY &
INFRASTRUCTURE
SECURITY AGENCY** </>[Menu](#)***America's Cyber Defense Agency***

NATIONAL COORDINATOR FOR CRITICAL INFRASTRUCTURE SECURITY AND RESILIENCE

SHARE:**BLOG**

Keynote by CISA Director Jen Easterly

During CISA's March 5-6 Open Source Software Security Summit

Released: March 06, 2024

By CISA Director Jen Easterly

RELATED TOPICS: [CYBERSECURITY BEST PRACTICES </topics/cybersecurity-best-practices>](#)

Good morning! Thank you all for joining us today at our CISA Open Source Software (OSS) Security Summit. I want to start by thanking you all for the incredibly important work that you do. The OSS community—all of you here today—provide such tremendous value to our country.

A recent Harvard study[1]

estimated that open source software has generated over eight *trillion* dollars in value to our society. That level of impact is astonishing, and the continued growth and successes of this movement are a testament to the underlying logics of open source that inherently promote and reward innovation and collaboration. This would not be possible without your tireless efforts to ensure that open source software is scaled in secure and

sustainable ways.

For those of you that are unfamiliar with CISA, we serve as the nation's lead cyber defense agency and the national coordinator for critical infrastructure resilience and security. We lead the effort to understand, manage, and reduce risk to the cyber and physical infrastructure that Americans rely on every hour of everyday, including water, power, transportation, communication, healthcare, finance, and education. Essentially, we work to protect and defend the networks, the systems, and the data that power our daily lives.

We at CISA are particularly focused on OSS security because, as everyone here knows, the vast majority of our critical infrastructure relies on open source software. And while the Log4Shell vulnerability might have been a big wakeup call for many in government, it demonstrated what this community has known and warned about for years: due to its widespread deployment, the exploitation of OSS vulnerabilities becomes more impactful.

The National Cybersecurity strategy specifically called for a fundamental shift in how we think about the burden of cybersecurity and the imperative to shift it from those least capable of managing it—like individuals, small businesses, and hospitals—and move it to those that are better equipped—namely, the federal government and private technology manufacturers.

It is in that spirit I am honored and excited that all of you are joining us for this summit. I believe that together we can work through some new and innovative approaches to collectively help secure the OSS we all depend on.

GOVERNMENT'S ROLE

I can imagine that for some of you, this might be your first government-hosted event. Having spent time in the private sector prior to joining CISA, I also recognize and can appreciate that some of you might be skeptical of what government involvement might look like in this space.

To that end I want to be very clear: CISA does not seek to control or regulate the open source community. Instead, our goal is to show up, as a community member, and steer

our resources in ways that can help support secure by design open source software development practices and encourage its responsible usage. The federal government is one of the biggest users of open source software in the world; it only makes sense that it makes the requisite contributions back to the OSS community.

With that in mind, I'll take a few minutes to not only share how we at CISA are supporting OSS security efforts, but also how we look to promote this idea that everyone—from individuals, to companies, to governments—has a role to play in supporting the development, deployment, and actual use of secure software.

Last year we published CISA's Open Source Software Security Roadmap <<https://www.cisa.gov/resources-tools/resources/cisa-open-source-software-security-roadmap>>, which lays out how CISA plans to help enable the secure usage of OSS within the federal government and more broadly support a healthy, secure, and sustainable global OSS ecosystem.

In the past year, we've been driving forward on a number of areas in line with the roadmap, including publication of our Principles for Package Repository Security document <<https://www.cisa.gov/news-events/alerts/2024/02/08/cisa-partners-openssf-securing-software-repositories-working-group-release-principles-package>> that we collaborated on with the OpenSSF Securing Software Repositories Working Group. This document lays out a maturity model for the security of package repositories.

As we know, package repositories are uniquely positioned to improve the overall security posture of open source software in a way that benefits all users. At the same time, we recognize that these package repositories are so often resource constrained. My hope is that this summit will help foster discussion on how best to prioritize and support security improvements to this critical component in OSS supply chains.

Separately, we want to help foster real-time collaboration around security incidents. We're launching a new effort specifically for open source community members to enable voluntary collaboration and to share cyber defense information. We recognize that working with this community will be a little different than how we typically work with companies, especially given the unique international complexities at play due to open source's global nature. As such, your participation and feedback will be critical to ensuring this initiative is a success.

I think we are all in agreement that the security of OSS is at its best when everyone—volunteer contributors, foundations, companies and governments—are working together. And as we heard loud and clear in the responses to the request for information we put out with our colleagues at the White House last year, there is a lot of energy and interest around identifying areas for public-private collaboration that can help enhance our collective security efforts. My hope is that that our work around package repositories and real-time collaboration can offer a strong starting point. I very much look forward to continuing to work through your feedback on how we can improve these efforts and better support your work to improve the security of open source ecosystems.

THE ROLE OF SOFTWARE MANUFACTURERS

As for what the OSS community has been accomplishing, I am deeply appreciative of all of your efforts to lead the way in securing the open source ecosystem. From widespread deployment of multifactor authentication, to increasing adoption of package signing, to automatically generating Software Bill of Materials for open source projects, to funding rewrites of critical open source libraries in memory safe languages, your work has directly led to very tangible security improvements for software across the globe.

But with that, I do have one ask of all the software manufacturers. Most of you are likely familiar with our Secure by Design <<https://www.cisa.gov/securebydesign>>, or SBD work. This SBD campaign is a push for software manufacturers to build in security from the start, thereby taking more ownership of their customers' cybersecurity outcomes.

How software manufacturers approach open source software is fundamental to SBD. We need companies to be both responsible consumers of and sustainable contributors to the open software they use. This means properly vetting their open source software and contributing back—either through financial support or through contributions of employee time—to help ensure that everyone who relies on that OSS can benefit from increased quality and security.

Going back to that Harvard study, they estimated that the cost of creating the world's open source software is four billion dollars – many magnitudes smaller than the eight trillion dollars of value we get from it. For open source software to be foundationally more secure, software manufacturers must invest some of the value they get from open

source software back into the ecosystem. At the same time, software manufacturers must put away notions of profit-motivated insecurity leaving some open source software inherently less secure by default than proprietary versions.

I know that many of the companies represented here today have already made great strides in doing your part and I thank you for that. Now, I hope you will continue looking to ways to innovate and recruit other companies to follow your example in this space.

CONCLUSION

People from every corner of the planet are more connected today than they have been before, in part due to technological advancements and democratized ways of thinking that have directly grown out of the open source movement. A thriving open source ecosystem is a strong defense against a divided world—digital or otherwise. For all the benefits of open and collaborative code, however, there are those who seek to take advantage of these systems for evil purposes.

The hope, however, is that by strongly committing to collaborative open source principles *and* prioritizing security considerations early and often, it will be substantially more difficult for such bad actors to succeed. It is by intentionally and proactively prioritizing security principles—like those espoused by the secure by design campaign—that bad actors will have a harder time creating exploitable divides in the first place.

Which is all to say, we have come a long way in recent decades, but I think your work matters more today than it ever has before. It is important that the open source community continues to thrive, and it is also imperative that we do this work in close coordination. We at CISA stand ready to learn from you and enhance your work to make open source software safe.

Thank you, everyone, for your contributions and for joining our event. I look forward to continuing to work with everyone here to further secure the open source ecosystem.

Visit Open Source Software Security | CISA <<https://www.cisa.gov/opensource>> to learn more about CISA's work in OSS Security!

[1] Hoffmann, Manuel, Frank Nagle, and Yanuo Zhou. "The Value of Open Source Software." Harvard Business School Working Paper, No. 24-038, January 2024.

Related Articles

NOV 19, 2024 BLOG

USDA Stops Credential Phishing with FIDO Authentication [</news-events/news/usda-stops-credential-phishing-fido-authentication>](/news-events/news/usda-stops-credential-phishing-fido-authentication)

NOV 14, 2024 BLOG

CISA’s Vulnerability Management goes “Big” on Interns and the Results are Staggering! [</news-events/news/cisas-vulnerability-management-goes-big-interns-and-results-are-staggering>](/news-events/news/cisas-vulnerability-management-goes-big-interns-and-results-are-staggering)

OCT 02, 2024 BLOG

Region 8 Invites You to Secure Our World [</news-events/news/region-8-invites-you-secure-our-world-0>](/news-events/news/region-8-invites-you-secure-our-world-0)

AUG 21, 2024 BLOG

Shaping the legacy of partnership between government and private sector globally: JCDC [</news-events/news/shaping-legacy-partnership-between-government-and-private-sector-globally-jcdc>](/news-events/news/shaping-legacy-partnership-between-government-and-private-sector-globally-jcdc)

[Return to top](#)

- Topics** [</topics>](/topics)
- Spotlight** [</spotlight>](/spotlight)
- Resources & Tools** [</resources-tools>](/resources-tools)
- News & Events** [</news-events>](/news-events)
- Careers** [</careers>](/careers)
- About** [</about>](/about)

CISA Central

1-844-Say-CISA SayCISA@cisa.dhs.gov

CISA.gov

An official website of the U.S. Department of Homeland Security

[About CISA </about>](#)

[Budget and Performance <https://
www.dhs.gov/performance-
financial-reports>](https://www.dhs.gov/performance-financial-reports)

[DHS.gov <https://www.dhs.gov>](https://www.dhs.gov)

[Equal Opportunity & Accessibility </oedia>](#)

[FOIA Requests <https://
www.dhs.gov/foia>](https://www.dhs.gov/foia)

[No FEAR Act </no-fear-act>](#)

[Office of Inspector General <https://
www.oig.dhs.gov/>](https://www.oig.dhs.gov/)

[Privacy Policy </privacy-policy>](#)

[Subscribe](#)

[The White House <https://
www.whitehouse.gov/>](https://www.whitehouse.gov/)

[USA.gov <https://www.usa.gov/>](https://www.usa.gov/)

[Website Feedback </forms/
feedback>](#)